

Length Authority and Representation Canonicity at an SQIsign Verification Boundary

Dana Edwards

Public preprint, 12 August 2026

Abstract

We study length authority and representation canonicity at the public verification boundary of the SQIsign implementation at revision `dd133d7aca576c361a270c8e6434832535b42ecc`. Frozen evidence records a six-authority matrix comprising parameter levels 1, 3, and 5 under the reference and Broadwell x86 implementations. Across both public verification paths, all 2,656 tested undersized inputs produced AddressSanitizer findings before a candidate boundary repair; the repair converted all tested cases to clean pre-decode rejections. The detached verifier also accepted all 1,200 tested representations formed by appending one or sixteen declared bytes to 600 valid fixed-size KAT signatures. An exact-length guard rejected all such tested suffix aliases while preserving all 600 exact KAT signatures. A separate 2,400-pair field-encoding campaign found no accepted collision, illustrating why decoder aliasing alone does not imply verifier-level noncanonicity. Generic Lean theorems identify the structural boundary: accepted decoder fibers are injective exactly when accepted encodings are normalization fixed points, while the ordered x-only observable $(x(R), x(S), x(R - S))$ determines (R, S) only up to simultaneous negation. The results are bounded implementation and representation findings, not a forgery, key recovery, remote-code-execution result, deployment exploit, or defect in the mathematical security proof. The public artifact records the reported aggregates, authenticated source authority and harness material, representative raw sanitizer evidence, and an isolated exact-source replay. The SQIsign team independently confirmed both boundary conditions, stated that equivalent guards are present in its development tree, and authorized immediate public disclosure.

Keywords. SQIsign; parser safety; signature representation; canonical encoding; AddressSanitizer; formal verification; Lean.

1 Introduction

A verification function receives bytes together with an asserted extent. A fixed-size decoder may safely consume those bytes only after the extent has been checked. This apparently mundane ordering constraint is a security boundary: once a bare pointer enters a decoder, the evidence that the required bytes exist is no longer present in the decoder’s interface.

This paper develops a bounded case study for the SQIsign scheme [3] and implementation repository [6]. It separates three questions that are easy to conflate:

1. Does every public verification path reject an undersized input before fixed-size decoding?
2. Does a detached signature’s declared length participate in the accepted representation, or is only a fixed prefix consumed?

3. When two byte strings decode to the same mathematical data, can both reach an accepting verifier state?

The first property is false throughout the complete tested undersized x86 matrix at the pinned revision. The second question yields accepted suffix aliases at the detached pointer/length interface. The third requires a more careful answer: a targeted field-component decoder-collision campaign found only paired rejection, and a generic formal theorem shows that byte uniqueness depends on an accepted-normal-form property beyond mathematical object uniqueness.

Our contributions are deliberately narrow.

- We record a complete tested-domain falsification of pre-decode length authority for two public APIs across six x86 authorities.
- We record accepted overlong detached representations and distinguish this API-level fact from a strong-unforgeability conclusion.
- We evaluate a minimal candidate repair against undersized inputs, exact KAT signatures, and two suffix lengths.
- We connect the implementation findings to generic normalization and x-only quotient formal sources while retaining their distinct build and provenance status, without claiming a formal refinement theorem for production SQIsign.

2 Authority, evidence, and claim discipline

2.1 Frozen implementation authority

The audited authority is the repository `SQIsign/the-sqisign` at the 40-hex revision

`dd133d7aca576c361a270c8e6434832535b42ecc`.

The recorded matrix covers parameter levels 1, 3, and 5, each under the reference and Broadwell x86 implementation. We make no claim about another revision, architecture, backend, API wrapper, or deployment.

2.2 Evidence classes

The manuscript was assembled from two frozen research refs and a fresh isolated replay from the exact SQIsign source and historical harness commits. The public package preserves the per-authority result JSON, aggregate validation, complete successful replay transcript, representative raw sanitizer reports, harness material, source authority, and hashes. This supplies a reviewable reproduction record. The SQIsign team’s independent reproduction, reported in its maintainer response, provides a separate check; their private development source and raw logs were not supplied or audited.

No quantitative result in this preprint rests solely on a conversational or user-reported count. The evidence mapping and nearest nonclaims for the six headline claims appear in the repository’s `CLAIMS.md`.

3 Length authority before fixed-size decoding

Let $s_1 = 148$, $s_3 = 224$, and $s_5 = 292$ denote the signature byte sizes in the three recorded parameter profiles [1]. For each of two implementations and two public verification paths, the campaign called the API at every declared length $0, \dots, s_i - 1$. The zero-length case used a one-byte non-null allocation, separating the length contract from null-pointer behavior. The number of calls was therefore

$$2 \text{ APIs} \cdot 2 \text{ implementations} \cdot (148 + 224 + 292) = 2,656.$$

The two paths were the NIST-style `crypto_sign_open` interface and the detached `sqsign_verify` interface. At the pinned revision both paths allowed a bare signature pointer to reach fixed-size decoding before the provided length authorized the read.

Table 1: Complete recorded undersized-input matrix.

Variant	Calls	ASan findings	Clean pre-decode rejections
Pinned implementation	2,656	2,656	0
Candidate repair	2,656	0	2,656

Observation 1 (Bounded length-authority defect). *For every input in the recorded undersized x86 matrix, the pinned implementation produced an AddressSanitizer finding [5] rather than a clean pre-decode rejection. This falsifies the tested property that each public API rejects every undersized input before fixed-size signature decoding.*

This observation is an implementation-safety result under the recorded build and sanitizer configuration. It does not by itself establish remote code execution, confidentiality loss, or exploitability in any named deployment.

4 Detached suffix aliases

The detached verifier receives a signature pointer and a `siglen` argument. In the pinned implementation, the recorded source audit found that `siglen` did not govern entry into the fixed-size signature decoder. Consequently, the campaign evaluated each of 600 valid detached KAT signatures in three forms: exact length, one appended declared byte, and sixteen appended declared bytes.

Table 2: Recorded detached-signature results.

Representation	Pinned accepted	Repaired accepted
Exact fixed-size signature	600/600	600/600
Exact signature plus one byte	600/600	0/600
Exact signature plus sixteen bytes	600/600	0/600

At the C API boundary, these are distinct declared byte representations with a common valid fixed-size prefix, message, and verification result. We call them *suffix aliases*. This terminology avoids silently assuming that a formal security experiment defines the signature domain as arbitrary length-delimited strings. If the formal domain contains only fixed-size signatures, the extra suffix may lie outside the mathematical signature rather than constitute a second signature in that experiment. Therefore Table 2 is not, by itself, a strong-unforgeability theorem or an existential forgery.

5 Candidate boundary repair

The candidate patch inserts two dominating guards before signature decoding. For the signed-message path it rejects when `smLen < SIGNATURE_BYTES`, setting the output message length to zero. For detached verification it rejects unless `sigLen == SIGNATURE_BYTES`.

The recorded repaired matrix supplies three complementary checks:

1. all 2,656 undersized calls became clean rejections with no recorded AddressSanitizer finding;
2. all 600 exact KAT signatures remained accepted; and
3. all 1,200 tested suffix aliases were rejected.

This is closure over the complete tested x86 matrix, not a proof about all C callers or all parser defects. On 12 August 2026 the SQIsign team confirmed that exact equality is the intended detached contract: the signed-message API permits a longer buffer only because the bytes following the fixed signature are the message. The team also reported that equivalent boundary checks had been independently added to its private development tree before this report, reproduced the findings by undoing those checks, and obtained clean rejections after restoring them. We did not audit that private tree; “equivalent” here records the reported guard semantics rather than source identity or upstream review of our candidate patch.

6 Why parser aliasing is not enough

The lower field decoder reports whether an encoding is canonical. The frozen source audit records paths where the enclosing conversion advances past a field element without propagating the combined canonicity mask. Two inputs may therefore decode to the same internal field value without having the same bytes. Acceptance, however, can restore uniqueness by rejecting the decoded object for an independent algebraic reason.

The campaign tested this distinction directly. In each of 600 accepted KAT objects and at four serialized field components, it replaced the component by canonical zero and by the distinct non-canonical encoding of the field modulus p . This produced 2,400 decoder-collision pairs and 4,800 mutated verifier calls. All 2,400 pairs were paired rejections, with no verdict or recorded first-rejection-stage divergence. Public-key coefficient mutations reached `challenge_even_isogeny_evaluation`; auxiliary-curve coefficient mutations reached `commitment_theta_codomain_not_split`.

This is useful negative evidence for four component families. It is not a universal proof of canonical fixed-length serialization, nor does it negate the accepted detached suffix aliases in Section 4; the experiments address different representation layers.

7 Structural canonicity theorems

The accompanying Lean development separates mathematical fibers from byte normal forms.

7.1 Normalization fixed points

Let $D : B \rightarrow O$ decode byte representations, $E : O \rightarrow B$ encode objects, and $V : O \rightarrow \{\text{true}, \text{false}\}$ verify objects. Define

$$N(b) = E(D(b)), \quad A(b) = V(D(b)).$$

Assume $D(E(o)) = o$ for every object o .

Proposition 1 (Accepted-fiber normalization criterion). *The decoder is injective on accepted fibers if and only if every accepted byte string is a fixed point of N . Moreover, any accepted b with $N(b) \neq b$ immediately yields two distinct accepted representations, b and $N(b)$, with equal decoded objects.*

Proof idea. Normalization preserves decoded objects by the section law and therefore preserves acceptance. Accepted-fiber injectivity forces $N(b) = b$. Conversely, two accepted bytes in one decoder fiber have one common normal form; if both are fixed points, they are equal. The frozen Lean source `CanonicalNormalization.lean` contains this generic proof without placeholders. The 2026-08-11 preparation record recompiles the exact frozen source using Lean 4.19.0 and the recorded Mathlib commit. The new local transcript, rather than the mismatched earlier receipt, controls any machine-checked wording. $\square$

This proposition captures the inner ground for canonical acceptance: accepted bytes must already be the selected normal form. It does not instantiate the pinned SQIsign decoder or verifier.

7.2 The ordered x-only quotient

For points on an affine Weierstrass curve over a field, define

$$X(R, S) = (x(R), x(S), x(R - S)),$$

using a separate value for the point at infinity. The classical elliptic x -line is a sign quotient; related quotient geometry appears in [2, 4]. The accompanying Lean development checks the exact ordered-pair statement:

$$X(R', S') = X(R, S) \iff (R', S') = (R, S) \text{ or } (R', S') = (-R, -S).$$

Thus the induced map from the simultaneous-sign quotient is injective. The third coordinate synchronizes the otherwise independent endpoint signs via the identities $S = R - (R - S)$ and $R = (R - S) + S$.

This is a mathematical object theorem. Byte uniqueness additionally needs a production refinement showing that every accepted serialization is the chosen orbit normal form. No such refinement theorem is claimed here.

8 Security interpretation and limitations

The evidence supports two distinct bounded conclusions. First, supplied lengths did not dominate fixed-size decoding for either tested verification path. Second, detached verification accepted tested suffix aliases at its pointer/length boundary. Neither conclusion depends on treating the generic x-only quotient theorem as a production verifier theorem.

The nearest likely overclaims are expressly excluded:

- no invalid signature for a new message was produced;
- no secret key was recovered;
- no remote-code-execution or deployment-specific exploitability claim is made;
- no flaw in the mathematical SQIsign security proof is established;
- no universal serialization-canonicity theorem is established;

- no EUF-CMA or SUF-CMA conclusion follows without fixing and analyzing the exact formal representation domain; and
- the candidate repair is not claimed to eliminate every parser defect, and the team’s private development source was not audited here.

The public package contains the minimum replay material, per-authority result JSON, representative raw ASan reports, formal sources, and validation records. The full internal research archive is not required to reproduce the bounded claims and is not part of this release.

9 Maintainer response and disclosure status

The findings were privately reported on 11 August 2026. On 12 August 2026, Décio Luiz Gazzoni Filho replied on behalf of the SQIsign team. The response confirmed both boundary conditions, the intended exact detached-length contract, independent fixes in the development tree, and clean repaired reproduction. The team described the code as a reference implementation, stated that it has no responsible-disclosure policy, authorized immediate publication including a public issue, and said the fix would ship with the Round 3 release. No private source or release candidate was supplied for this study, so the affected authority remains the public pinned revision.

Public upstream `main` resolved to that same revision on 11 August 2026 and again when rechecked on 12 August 2026. The fresh replay therefore covers both the pinned and observed-current labels at those observation times; it does not assert the state of a later public commit.

10 Reproducibility map

The public artifact map is as follows:

- per-authority aggregate JSON and fresh replay validation: `artifact/evidence/results/` and `artifact/evidence/validation.json`;
- complete successful replay transcript and representative sanitizer reports: `artifact/evidence/command-transcript.log` and `artifact/evidence/raw/`;
- frozen harness and workflow material: `artifact/evidence/harness-material.tar`;
- candidate source patch: `artifact/patch/sqisign-dd133d7-h7-length-guards.patch`;
- formal normalization theorem: `artifact/lean/CanonicalNormalization.lean`;
- formal x-only fiber and quotient theorems: `artifact/lean/XCoordinateFiber.lean` and `artifact/lean/XOnlyQuotient.lean`; and
- release hashes and public claim boundaries: `SHA256SUMS` and `artifact/PUBLICATION_RECEIPT.json`.

AI-assistance statement

OpenAI Codex agents assisted with evidence triage, reproduction orchestration, drafting, and artifact assembly under Dana Edwards’s direction. Their output was treated as candidate material and checked against the preserved evidence. No AI system is an author.

References

- [1] Marius A. Aardal, Gora Adj, Diego F. Aranha, Andrea Basso, Isaac Andrés Canales Martínez, Jorge Chávez-Saab, Maria Corte-Real Santos, Pierrick Dartois, Luca De Feo, Max Duparc, Jonathan Komada Eriksen, Tako Boris Fouotsa, Décio Luiz Gazzoni Filho, Basil Hess, David Kohel, Antonin Leroux, Patrick Longa, Luciano Maino, Michael Meyer, Kohei Nakagawa, Hiroshi Onuki, Lorenz Panny, Sikhar Patranabis, Christophe Petit, Giacomo Pope, Krijn Reijnders, Damien Robert, Francisco Rodríguez-Henríquez, Sina Schaeffler, and Benjamin Wesolowski. SQIsign: Algorithm specifications and supporting documentation. Additional post-quantum signature round 2 specification Version 2.0.1, National Institute of Standards and Technology, July 2025. Dated 7 July 2025.
- [2] Craig Costello and Benjamin Smith. Montgomery curves and their arithmetic. arXiv:1703.01863, 2017.
- [3] Luca De Feo, David Kohel, Antonin Leroux, Christophe Petit, and Benjamin Wesolowski. SQIsign: Compact post-quantum signatures from quaternions and isogenies. In *Advances in Cryptology – ASIACRYPT 2020, Part I*, volume 12491 of *Lecture Notes in Computer Science*, pages 64–93. Springer, 2020.
- [4] David Kohel. Arithmetic of split kummer surfaces: Montgomery endomorphism of edwards products. arXiv:1601.03680, 2016.
- [5] Konstantin Serebryany, Derek Bruening, Alexander Potapenko, and Dmitriy Vyukov. AddressSanitizer: A fast address sanity checker. In *2012 USENIX Annual Technical Conference (USENIX ATC 12)*, pages 309–318. USENIX Association, 2012.
- [6] SQIsign implementation repository. <https://github.com/SQIsign/the-sqisign>. Implementation authority audited at revision dd133d7aca576c361a270c8e6434832535b42ecc.